

IoT & OT: The Invisible Attack Surface

Two Different Worlds

IoT (Internet of Things) – consumer/edge gadgets: cameras, thermostats, medical sensors

OT (Operational Technology) – industrial control: PLCs, SCADA, power grid, factory robots, HVAC in your building

Both are computers with no security culture of their own: cheap, internet-exposed, rarely patched, no one's favorite child.

Why They're Security's Nightmare

Property	Classic IT	IoT/OT
Patching	monthly	sometimes <i>never</i> (uptime, vendor lock)
Attacker's prize	data	physical systems & availability
Traffic	network-complex, monitored	proprietary, messy, sometimes isolated
People	security teams	nobody owns them (IT says OT, OT says IT)
Blast radius	business	safety, lives

Consequence moments (learn the stories):

Mirai (2016) – IoT botnet of cameras/DVRs → massive DDoS via default creds

Colonial Pipeline (2021) – IT breach → OT shutdown → fuel panic + ransom payment

NotPetya (2017) – spread to OT → Maersk lost almost all systems, US\$300M loss

Stuxnet (2010) – the OG: sabotaged Iranian centrifuges (M08)

The Layered Reality

The IT/OT boundary: IT network ← DMZ/gateway → OT network → PLCs → devices

The dangerous part: modern OT is **converged** (it talks to the internet for telemetry) – the old 'air-gapped' dream is dead.

The Default-Credential Epidemic

Cameras shipped with **admin/admin**, never changed

Scanned by bots within **minutes** of going online

The Mirai pattern: it's not a hack, it's a plucking of the default orchard

```
# How Mirai scanned: try the common defaults against the garden of devices:
# admin/admin, root/123456, support/support, etc.
nmap -p 23 --open 192.168.1.0/24 # finds telnet-enabled cameras/Linux-ish boxes
```

The Security-by-Omission of Vendors

No secure boot / signed firmware

No auto-update path an ORG can control

Hard-to-change passwords, web UIs over HTTP

Little logging worth anything

The Realistic OT Program (what CSIRTs do)

Inventory – you can't protect the invisible: list every device, vendor, firmware, network position

Segment (zones & conduits) – the IoT/OT network is a *separate zone*, guards in both directions, NO direct internet

Credential discipline – change defaults on day one; centralized auth where possible

Patch WHAT CAN be patched; gate the rest behind controls

Monitor the boundaries – anomalies: a PLC calling the internet = incident

Run the incident process for OT differently – 'go-fast' interrupts safety procedures; the response plan must respect the process (plant rules)

The OT reality-check: in ICS, remediators can't necessarily 'just reboot' – an emergency stop or PLC restart may be worse than the malware. Response in OT = plan, pause, and process, not cowboy speed.

[← Module start](#)

[ICS Protocols & Their Attacks →](#)